

CIBERSEGURIDAD BANCARIA EN URUGUAY: BCU

[INICIO](#) / [BLOG](#) / CIBERSEGURIDAD BANCARIA EN URUGUAY: BCU

CIBERSEGURIDAD BANCARIA EN URUGUAY: BCU, LEY 18.331 Y ESTÁNDARES INTERNACIONALES

Uruguay cuenta con un marco regulatorio de ciberseguridad bancaria articulado por el Banco Central del Uruguay (BCU), que adopta estándares internacionales como ISO/IEC 27001:2013, COBIT 5 y NIST SP 800-53. La Ley N° 18.331 establece los principios de protección de datos personales, y el BCU hace cumplir sus requisitos mediante sanciones concretas, como la multa impuesta al Banco Hipotecario del Uruguay (BHU) en 2022 por incumplimiento continuado.

Ley N° 18.331 – Protección de Datos Personales en Uruguay

La Ley N° 18.331 es la norma marco de protección de datos personales en Uruguay. Establece principios de protección integral que aplican a toda entidad que trate datos de ciudadanos uruguayos, incluyendo instituciones financieras y fintechs.

Entre sus principios centrales destacan el consentimiento informado, la finalidad limitada del tratamiento de datos, la proporcionalidad en el uso de información personal y el derecho de los titulares a acceder, rectificar y cancelar sus datos. Su Decreto Regulatorio complementa la ley con requisitos específicos sobre medidas de seguridad y notificación de incidentes.

¿Tu empresa necesita ciberseguridad?

WhiteJaguars ofrece servicios de seguridad adaptados a tu industria y tamaño.

CONSULTA GRATUITA

Para bancos y fintechs que operan en Uruguay, esta ley es el punto de partida: define qué datos pueden recopilarse, durante cuánto tiempo pueden conservarse y cómo deben protegerse. La [gestión de vulnerabilidades](#) continua es una de las medidas de seguridad que permite demostrar cumplimiento ante las autoridades.

BCU – Guía de Seguridad de la Información

El Banco Central del Uruguay publicó su Guía de Seguridad de la Información, que establece los estándares mínimos que deben cumplir las entidades del sistema financiero uruguayo. Esta guía se fundamenta en tres marcos internacionales de referencia:

- **ISO/IEC 27001:2013**: norma internacional para sistemas de gestión de seguridad de la información.
- **COBIT 5 para Seguridad de la Información**: marco de gobernanza y gestión de TI orientado al control de riesgos.
- **NIST SP 800-53 rev.4**: catálogo de controles de seguridad del **Instituto Nacional de Estándares y Tecnología de EE.UU.**.

La adopción de estos tres marcos en conjunto indica que el BCU exige un nivel de madurez de seguridad comparable al de jurisdicciones financieras más desarrolladas. Las entidades que ya aplican ISO 27001 tienen ventaja, pero deben revisar también los controles específicos de NIST SP 800-53 y la capa de gobernanza de COBIT 5.

Protección de datos bancarios: backups y recuperación

La guía del BCU incluye requisitos concretos sobre continuidad y protección de datos:

- **Backups diarios**: todas las entidades financieras deben ejecutar respaldos diarios de sus datos críticos.
- **Copia fuera del centro de procesamiento**: el backup debe almacenarse en una ubicación física separada del sitio principal, de modo que un incidente en el centro de datos primario no destruya simultáneamente producción y respaldo.
- **Restauración validada periódicamente**: no basta con hacer backups; la regulación exige demostrar que los datos de cualquier día pueden recuperarse efectivamente. Las pruebas de restauración deben realizarse de forma periódica y documentarse.

Este enfoque de protección de datos complementa los requisitos de las pruebas de **pentest** que permiten identificar vulnerabilidades en los sistemas que gestionan esos backups antes de que sean explotadas.

Estándares de seguridad electrónica: autenticación y monitoreo

Para las operaciones financieras digitales, el BCU establece controles específicos orientados a proteger a los usuarios finales:

Autenticación de dos factores obligatoria para: - Transferencias desde cuenta bancaria. - Pagos a terceros.

Este requisito aplica a todos los canales digitales: banca en línea, aplicaciones móviles y cualquier interfaz que permita mover fondos. La autenticación de un solo factor (usuario y contraseña) no es suficiente para estas operaciones.

Monitoreo de cambios en datos sensibles: las entidades deben registrar y controlar cualquier modificación en los siguientes datos del cliente:

- Número de identificación personal.
- Dirección.
- Teléfono de contacto.
- Correo electrónico de contacto.

El monitoreo de cambios en estos campos permite detectar ataques de ingeniería social donde un actor malicioso intenta redirigir las comunicaciones del cliente para tomar control de su cuenta. La **ciberseguridad** efectiva en el sector bancario no puede limitarse a proteger los sistemas internos; debe abarcar también la protección del ciclo de vida de los datos del cliente.

BCU y AGESIC – Convenio de Cooperación

El BCU firmó un Convenio de Cooperación con AGESIC (Agencia de Gobierno Electrónico y Sociedad de la Información y del Conocimiento) con tres objetivos principales:

1. **Fortalecimiento de capacidades**: desarrollar las competencias de ciberseguridad en las entidades financieras supervisadas por el BCU.
2. **Generación y difusión de conocimiento**: crear y distribuir materiales técnicos, guías y mejores prácticas aplicables al sector.
3. **Habilidades especializadas**: capacitar al personal de las entidades financieras en detección de amenazas, respuesta a incidentes y gestión de riesgos de TI.

Este convenio es relevante porque convierte a la ciberseguridad bancaria en Uruguay en un esfuerzo coordinado a nivel país, no solo en una obligación regulatoria sectorial. Las entidades financieras que participan activamente en estas iniciativas tienen acceso a inteligencia de amenazas y mejores prácticas del ecosistema nacional.

Enforcement — El caso BHU (2022)

El BCU no limita su rol a la emisión de normas: también ejerce su poder de enforcement. En 2022, el Banco Hipotecario del Uruguay (BHU) fue sancionado con una multa monetaria por violaciones continuas a los requisitos de protección establecidos por el BCU.

Este caso es importante por dos razones:

- **Demuestra que el BCU monitorea activamente** el cumplimiento de sus normas de seguridad, no solo en el momento de la autorización, sino durante toda la vida operativa de la entidad.
- **Las violaciones continuas se sancionan acumulativamente:** no es una advertencia seguida de corrección; si el incumplimiento persiste, la sanción económica sigue.

Para cualquier entidad financiera en Uruguay, este precedente establece que el costo de no cumplir supera ampliamente el costo de implementar un programa estructurado de seguridad de la información.

Si te interesa conocer cómo otros países de la región afrontan la seguridad bancaria con marcos menos desarrollados, puedes revisar la [regulación de seguridad de la información en Bolivia](#), que opera sin ley marco de protección de datos pero con regulación sectorial de la ASFI.

¿Tu organización opera en el sector financiero uruguayo y necesita alinear su programa de seguridad con la guía del BCU e ISO/IEC 27001? Contáctanos para una evaluación inicial o conoce cómo nuestros servicios de [gestión de vulnerabilidades](#) pueden apoyar el cumplimiento regulatorio en Uruguay.

Publicado el 2026-06-23T00:31:59+00:00

Mario Robles

CEO & Founder

Hacker Ético con más de 20 años de experiencia, creador de herramientas de ciberseguridad, ex-líder de OWASP Costa Rica y miembro activo de Cybersec Cluster y el capítulo de ciberseguridad de CAMTIC.

[← Volver al Blog](#)

TAMBIÉN TE PODRÍA INTERESAR

BCP PARAGUAY: CIBERSEGURIDAD Y CLOUD BANKING

El BCP regula la ciberseguridad bancaria con Resolución 12/2021 y cloud computing para entidades financieras. Obligaciones mínimas para bancos en Paraguay.

LEER: BCP PARAGUAY: CIBERSEGURIDAD Y CLOUD ... →

CONASSIF 5-24: CIBERSEGURIDAD EN COSTA RICA

El CONASSIF 5-24 regula gobernanza y ciberseguridad de entidades financieras en Costa Rica. Qué exige sobre resiliencia operacional, TI y alta dirección.

LEER: CONASSIF 5-24: CIBERSEGURIDAD EN COST... →

CIBERSEGURIDAD EN REPÚBLICA DOMINICANA

La Ley 133-21 y el Reglamento de Seguridad Cibernética de la Junta Monetaria exigen ISO 27001 y NIST a entidades financieras de República Dominicana.

LEER: CIBERSEGURIDAD EN REPÚBLICA DOMINICANA →

¿NECESITAS AYUDA?

VER MÁS ARTÍCULOS

Nuestro equipo de especialistas puede ayudarte a implementar las mejores prácticas de ciberseguridad en tu organización.



CONSULTA GRATUITA
White Jaguars

SERVICIOS RELACIONADOS

Más de 10 años brindando servicios exclusivos de ciberseguridad en más de 10 países.

- [Hacking Ético y Pentest](#)
- [Análisis de Vulnerabilidades](#)
- [Asesoría de Ciberseguridad](#)
- [Gestión de Vulnerabilidades](#)

SERVICIOS

[Pentest como servicio continuo \(PTaaS\)](#)

ARTÍCULOS RELACIONADOS

- [BCP Paraguay: ciberseguridad y cloud banking](#)
- [CONASSIF 5-24: ciberseguridad en Costa Rica](#)
- [Ciberseguridad en República Dominicana](#)
- [Ver todos los artículos →](#)

- [Certificación de aplicaciones Web y Móvil](#)
- [Pruebas manuales de penetración \(Pentest\)](#)
- [Protección de marca](#)

CONTACTARNOS

 info@whitejaguars.com
[¿Necesitas proteger tu empresa?](#)

 [+\(506\) 2505-5402](tel:+59625055402)
CONSULTA GRATUITA

 [+1 732-481-2777](tel:+17324812777)



WhiteJaguars está disponible en Uruguay por medio de AppSec S.C.
Todos los derechos reservados, WhiteJaguars Inc, Delaware, Estados Unidos, 2026